

Risk register

Risk register

Operational environment:

The bank is located in a coastal area with low crime rates. Many people and systems handle the bank's data—100 on-premise employees and 20 remote employees. The customer base of the bank includes 2,000 individual accounts and 200 commercial accounts. The bank's services are marketed by a professional sports team and ten local businesses in the community. There are strict financial regulations that require the bank to secure their data and funds, like having enough cash available each day to meet Federal Reserve requirements.

Asset	Risk(s)	Description	Likelihood	Severity	Priority
Funds	Business email compromise	<i>An employee is tricked into sharing confidential information.</i>	2	2	4
	Compromised user database	<i>Customer data is poorly encrypted.</i>	2	3	6
	Financial records leak	<i>A database server of backed up data is publicly accessible.</i>	3	3	9
	Theft	<i>The bank's safe is left unlocked.</i>	1	3	3
	Supply chain disruption	<i>Delivery delays due to natural disasters.</i>	1	2	2
Notes	Security incidents threatening the bank's funds and data are possible because the operating environment relies heavily on interconnected systems and the human factor. Furthermore, doing business with other companies creates additional avenues for information to be compromised. Regarding digital vulnerabilities, it is crucial to highlight that, in the real world, if a server containing data backups is publicly exposed, the likelihood of it being discovered and exploited is imminent, demanding top-priority intervention. Conversely, in the physical realm, while the risk of theft is significant, it may not be an immediate priority because the bank is located in a low-crime area.				

Asset: The asset at risk of being harmed, damaged, or stolen.

Risk(s): A potential risk to the organization's information systems and data.

Description: A vulnerability that might lead to a security incident.

Likelihood: Score from 1-3 of the chances of a vulnerability being exploited. A 1 means there's a low likelihood, a 2 means there's a moderate likelihood, and a 3 means there's a high likelihood.

Severity: Score from 1-3 of the potential damage the threat would cause to the business. A 1 means a low severity impact, a 2 is a moderate severity impact, and a 3 is a high severity impact.

Priority: How quickly a risk should be addressed to avoid the potential incident. Use the following formula to calculate the overall score: **Likelihood x Impact Severity = Risk**

Sample risk matrix

		Severity		
Likelihood		Low 1	Moderate 2	Catastrophic 3
	Certain 3	3	6	9
	Likely 2	2	4	6
	Rare 1	1	2	3

Registros de Riesgo

Registro de riesgos

Entorno operativo:

El banco está ubicado en una zona costera con bajos índices de criminalidad. Muchas personas y sistemas manejan los datos del banco: 100 empleados en las instalaciones y 20 empleados remotos. La base de clientes del banco incluye 2,000 cuentas individuales y 200 cuentas comerciales. Los servicios del banco son promocionados por un equipo deportivo profesional y diez negocios locales de la comunidad. Existen regulaciones financieras estrictas que exigen que el banco asegure sus datos y fondos, como tener suficiente efectivo disponible cada día para cumplir con los requisitos de la Reserva Federal.

Activo	Riesgo(s)	Descripción	Probabilidad	Severidad	Prioridad
Fondos	Compromiso de correo electrónico empresarial	<i>Un empleado es engañado para compartir información confidencial.</i>	2	2	4
	Base de datos de usuarios comprometida	<i>Los datos de los clientes están mal encriptados.</i>	2	3	6
	Filtración de registros financieros	<i>Un servidor de base de datos con copias de seguridad es accesible públicamente.</i>	3	3	9
	Robo	<i>La caja fuerte del banco se deja abierta.</i>	1	3	3
	Interrupción de la cadena de suministro	<i>Retrasos en las entregas debido a desastres naturales.</i>	1	2	2
Notas	<i>Los eventos de seguridad que amenazan los fondos y datos del banco son posibles porque el entorno operativo depende fuertemente de sistemas interconectados y del factor humano. Además, hacer negocios con otras compañías presenta vías adicionales para que la información sea comprometida. Dentro de las vulnerabilidades digitales, es imperativo destacar que, en el mundo real, si un servidor con copias de seguridad de datos está expuesto públicamente, la probabilidad de que sea descubierto y explotado es inminente, requiriendo la máxima prioridad de intervención. Por otro lado, en el ámbito físico, el riesgo de robo es importante, pero podría no ser una prioridad inmediata porque el banco se encuentra en un área con bajos índices de criminalidad.</i>				

Activo: El activo con riesgo de ser dañado, perjudicado o robado.

Riesgo(s): Un riesgo potencial para los sistemas de información y los datos de la organización.

Descripción: Una vulnerabilidad que podría dar lugar a un incidente de seguridad.

Probabilidad: Puntuación del 1 al 3 de las posibilidades de que una vulnerabilidad sea explotada. Un 1 significa que hay una probabilidad baja, un 2 significa que hay una probabilidad moderada y un 3 significa que hay una probabilidad alta.

Severidad: Puntuación del 1 al 3 del daño potencial que la amenaza causaría al negocio. Un 1 significa un impacto de severidad baja, un 2 es un impacto de severidad moderada y un 3 es un impacto de severidad alta.

Prioridad: Qué tan rápido debe abordarse un riesgo para evitar el incidente potencial. Utilice la siguiente fórmula para calcular la puntuación global: **Probabilidad x Severidad del impacto = Riesgo**

Ejemplo de matriz de riesgos

		Severity		
Likelihood		Baja 1	Moderada 2	Catastrófica 3
	Cierta 3	3	6	9
	Probable 2	2	4	6
	Rara 1	1	2	3